

Executive Summary

Data Inventory and Record of Processing Activities (ROPA) Project

Introduction

This project was developed to demonstrate how a privacy professional can create practical governance documentation that provides a clear view of how personal data is used across an organization.

Using a fictional mid-sized e-commerce company as the case study, I prepared a complete Data Inventory and a GDPR-aligned Record of Processing Activities (ROPA). The goal was to identify where personal data is collected, how it is processed, which systems and third parties are involved, how long the data is retained, and which activities present the highest privacy risks.

To make the analysis more meaningful for business stakeholders, I also created a data flow diagram and an executive dashboard in Google Looker Studio. Together, these deliverables simulate the type of work performed during privacy assessments, GDPR readiness projects, and data governance initiatives.

Project Scope

The project covers personal data processing across major business functions, including:

- Customer Operations
- Marketing
- Finance
- Human Resources
- Operations
- Information Technology
- IT Security
- Privacy Office
- Compliance

A total of **30 processing activities** were documented, covering both customer and employee data, as well as interactions with external vendors and service providers.

Examples of processing activities include:

- Customer Registration
- Order Fulfilment
- Payment Processing
- Email Marketing

- Website Analytics
 - Recruitment
 - Payroll Administration
 - Employee Health Benefits
 - Security Monitoring
 - Data Subject Requests
 - Incident Management
-

Methodology

The project was completed in five stages.

1. Data Inventory

I identified all systems, applications, and vendors that store or process personal data. This included CRM platforms, payment gateways, HR systems, customer support tools, analytics platforms, and compliance applications.

2. Record of Processing Activities (ROPA)

For each activity, I documented:

- Responsible department
- Purpose of processing
- Data subjects affected
- Categories of personal data
- Legal basis
- Systems used
- Third-party recipients
- International transfers
- Retention periods
- Risk level
- DPIA requirements

3. Data Flow Mapping

A visual data flow diagram was created to show how information moves between customers, employees, internal systems, and external vendors.

4. Privacy Risk Assessment

Each activity was evaluated based on the sensitivity of the data involved, cross-border transfers, operational impact, and regulatory obligations.

5. Executive Dashboard

A dashboard was developed to present privacy metrics and trends in a concise format suitable for management reporting. Link to Dashboard:
<https://datastudio.google.com/reporting/6c732ab0-3b24-450b-8581-0ad48fc102ee>

Executive Dashboard Highlights

The dashboard summarized the project into a set of measurable privacy indicators.

Metric	Result
Processing Activities Documented	30
Systems Containing Personal Data	29
High-Risk Activities	10
Average Retention Period	5.13 Years
International Transfers	27
Activities Requiring DPIA	7

These metrics help translate detailed privacy records into actionable insights for decision-makers.

Key Findings

Personal Data is Widely Distributed Across the Organization

The analysis showed that personal data is processed in **29 different systems**, confirming that privacy responsibilities extend well beyond a single department.

High-Risk Processing Represents a Significant Portion of Operations

Out of 30 documented activities, **10 were classified as High Risk**, representing roughly one-third of the organization's processing landscape. These activities typically involved security monitoring, fraud detection, whistle-blower reporting, and sensitive employee data.

International Transfers are Common

27 processing activities involve transfers to other countries, primarily through cloud-based vendors and SaaS platforms. This emphasizes the importance of transfer assessments and contractual safeguards.

Retention Periods Average Just Over Five Years

The average retention period across all activities is **5.13 years**. While some records are retained only for a few months, others must be kept for up to ten years due to legal and financial obligations.

Sensitive Data Requires Additional Oversight

Several activities process special category or highly confidential data, particularly in employee health benefits, whistle-blower reporting, and backup systems.

Legal Basis Analysis

The legal basis review showed that most processing activities rely on a combination of operational and regulatory justifications.

- **Legitimate Interests (33.3%)** – Used for security, monitoring, and internal administration
- **Legal Obligation (26.7%)** – Applied to payroll, accounting, and compliance functions
- **Contract (20.0%)** – Supports customer-facing operations such as registration and order fulfilment
- **Consent (13.3%)** – Used for marketing and cookie management
- **Contract / Legal Obligation and Employment Law** – Used in specialized scenarios

This distribution reflects a balanced and realistic privacy governance framework.

Departmental Insights

The highest number of processing activities were concentrated in:

- Marketing
- Human Resources
- Finance
- Operations
- Compliance
- IT and IT Security

This indicates that privacy management must be coordinated across both customer-facing and internal support functions.

Recommendations

Based on the findings, the following actions are recommended:

- 1) Conduct DPIAs for activities identified as high risk.
- 2) Review and document transfer mechanisms for international data flows.
- 3) Reassess retention schedules to reduce unnecessary storage.

- 4) Strengthen third-party due diligence and contract management.
 - 5) Expand monitoring of sensitive data processing.
 - 6) Use dashboards to track privacy metrics on an ongoing basis.
-

Business Value

This project demonstrates how privacy documentation can be transformed into a management tool rather than treated solely as a compliance requirement.

By combining structured records, risk assessments, and analytics, organizations can:

- Gain visibility into how personal data is used
 - Prioritize compliance efforts
 - Identify high-risk activities
 - Improve vendor oversight
 - Support executive decision-making
-

Personal Reflection

This project allowed me to apply privacy governance concepts in a practical and business-oriented way. More importantly, it showed how privacy data can be analysed and presented in a format that is meaningful to leadership.

Creating the dashboard was particularly valuable because it connected detailed compliance work with data analytics and visualization, two skills that are increasingly important in privacy and governance roles.

Conclusion

The Data Inventory and ROPA project provides a comprehensive view of how personal data is processed across an organization. It combines regulatory documentation, operational analysis, risk assessment, and executive reporting into a single portfolio project.

The exercise reinforced an important lesson: effective privacy governance is not only about meeting regulatory requirements—it is about creating transparency, accountability, and trust in how organizations handle personal data.